

GoldFin Desk — Multi-Factor Authentication (MFA) Policy

Version: 2026-06-26.1 **Owner:** Chris Sam, Founder **Last reviewed:** 2026-06-26 **Review cadence:** Quarterly + triggered (see §11)

1. Purpose

This policy defines how GoldFin Desk authenticates every human identity that can access the GoldFin portal or any system that handles end-user financial data obtained through Plaid. It exists to satisfy Plaid's End User Services Agreement (EUSA) §5 (access controls), Plaid's Production Access security review (authentication & session management), SOC 2 CC6.1 / CC6.6 (logical access and MFA), NIST SP 800-63B AAL2, PCI-DSS 8.4 (MFA into the CDE), and the storage-limitation, integrity, and confidentiality principles of GDPR Art. 5.

GoldFin Desk operates a **passwordless, MFA-by-default** authentication model. There is no password-only sign-in path anywhere in the product.

2. Scope

This policy applies to:

- All end users of the GoldFin portal (/portal/*).
- All administrators (any account in the `user_roles` table with `role = admin`).
- All employees, contractors, and sub-processors with access to GoldFin systems.
- Every authentication event that precedes a Plaid Link session, a Plaid token exchange, or any read of Plaid-derived data.

3. Authentication factors in use

GoldFin offers two equivalent strong-authentication paths. Both satisfy NIST AAL2.

Path	Factor 1	Factor 2	Notes
Email OTP	Possession of the verified email mailbox	One-time code delivered out-of-band	6-digit, single-use, 10-minute TTL

Path	Factor 1	Factor 2	Notes
Google OAuth	Possession of the Google account	Google-enforced 2-Step Verification	We require Google accounts that have 2SV enabled; federation transmits the assurance

Neither path uses a reusable password. Knowledge-based authentication, SMS OTP, and security questions are explicitly out of scope.

4. Email OTP — technical controls

- **Generator:** 6-digit numeric, generated server-side with a CSPRNG inside the `send-login-otp` edge function.
- **Storage:** Hashed (SHA-256) and stored in `auth_otp_codes`; raw codes are never persisted.
- **Delivery:** Resend, from Goldfin Desk <noreply@goldfindesk.com>, over TLS 1.2+.
- **TTL:** 10 minutes from issuance.
- **Single-use:** Marked consumed atomically on first successful verification; replays are rejected.
- **Rate limits:** Max 5 issuance requests per email per hour; max 5 verification attempts per code. Excess triggers a 15-minute soft lock with security-team alert.
- **Enumeration resistance:** The endpoint returns the same response shape whether the email is known or unknown.
- **Transport:** All OTP traffic is HTTPS-only; HSTS is enabled on the root domain.

5. Google OAuth — federation controls

- **Provider:** Google as identity provider via Lovable Cloud auth.
- **Scopes requested:** `openid email profile` — no Gmail, Drive, or Calendar scopes.
- **Account binding:** First successful sign-in binds the Google subject ID to the user record. Subsequent sign-ins require the same subject ID; email changes alone are insufficient.
- **2SV expectation:** Users are instructed during onboarding to enable Google 2-Step Verification; GoldFin treats the Google assertion as a strong factor on that basis.
- **Token handling:** OAuth tokens are exchanged server-side; the client receives only the GoldFin session JWT.

6. Enforcement — no path bypasses MFA

- The portal has no username/password form. The only authenticated entry points are `/portal/login` (Email OTP) and the Google OAuth button on the same page.
- Legacy paths (`/portal/signup`, `/portal/forgot-password`, `/portal/reset-password`) are routed to `/portal/login` in `PortalRouter.tsx` so no alternate flow can be discovered.
- Every protected route is wrapped in `ProtectedRoute.tsx`, which redirects unauthenticated requests to `/portal/login`.
- Edge functions that touch Plaid (`plaid-create-link-token`, `plaid-exchange-public-token`, `plaid-get-accounts`, `plaid-get-transactions`) require a valid JWT and re-verify `auth.uid()` server-side.

7. Privileged access (administrators)

- The `admin` role is stored in `user_roles`, never on the user or profile row, and is checked through the `public.has_role()` security-definer function used in RLS policies.
- Admins authenticate with the exact same Email OTP or Google OAuth flow as end users — there is no separate admin login.
- The admin audit dashboard (`/portal/admin/audit`) is gated by `has_role(auth.uid(), 'admin')`; non-admins receive a 404-equivalent.
- Service-role keys are used only inside edge functions and are never delivered to the browser.

8. Session policy

- **Access-token lifetime:** 1 hour, signed JWT (HS256), validated on every edge-function call.
- **Refresh-token rotation:** Enabled; reused refresh tokens revoke the entire session family.
- **Idle timeout:** 30 minutes of inactivity invalidates the session client-side; the next request is redirected to `/portal/login`.
- **Absolute timeout:** 24 hours from initial sign-in, regardless of activity.
- **Plaid Link re-auth:** A fresh authentication assertion (new OTP or recent OAuth) within the last 30 minutes is required before `plaid-create-link-token` returns a token. Older sessions are forced through MFA before Link can open.
- **Logout:** Revokes the refresh token server-side and clears all client storage keys.

9. Account recovery

- The only recovery mechanism is delivery of a fresh OTP to the verified email address on file, or a fresh Google OAuth sign-in for accounts bound to Google. There are no security questions, no SMS resets, and no support-channel password resets.
- Email-address changes require successful OTP verification at both the old and new addresses.
- If a user loses access to their verified email, the account is locked and the user must contact security@goldfindesk.com; identity is re-established out-of-band before access is restored.

10. Logging, monitoring, and incident response

- All authentication events (issued, verified, failed, rate-limited, locked) are written to the audit log surfaced in `/portal/admin/audit`.
- All webhook deliveries are persisted in `webhook_events` for 90 days.
- Anomalies — repeated failed verifications, OTP issuance bursts, OAuth subject mismatches — trigger alerts to the on-call engineer.
- **Runbook on suspected credential compromise:**
 - Invalidate active sessions for the affected user (refresh-token revocation).
 - Force re-authentication on next request.
 - Mark every Plaid item on the account `reauth_required` and require a fresh Plaid Link session.
 - Notify the user within 72 hours of confirmed unauthorized access.
 - File a Plaid security report at security@plaid.com within 72 hours where Plaid-derived data is implicated.
 - Write a post-mortem within 5 business days with at least one durable control change.

11. Review cadence — how this policy stays continuously matured

- **Quarterly review** by founder + engineering lead, logged in the admin audit dashboard.
- **Triggered review** after any authentication incident, change to the auth surface, new identity provider, or new Plaid product surface.
- **Annual external review** against the then-current Plaid security review checklist, NIST 800-63B revision, and SOC 2 control set.
- **Version log** in §12 is appended at every review — even a "reviewed, no change" entry is recorded.

12. Change log

Version	Date	Author	Summary
2026-06-26.1	2026-06-26	Chris Sam	Initial published version. Email OTP + Google OAuth, AAL2, no password path.

Questions or reports of suspected authentication issues: security@goldfindesk.com.